

CryptoMacro Dashboard

Testing Report — Security Review, API Checks & Playwright E2E

Report date 2026-08-11 12:54 UTC

1. Objectives

Validate that the published dashboard works end-to-end: navigation, charts, portfolio, market APIs, and security controls. Failures found during automation were fixed and retested until the suite passed fully.

2. Environment

Item	Value
App under test	http://127.0.0.1:5173 (Vite dev, same code as production SPA)
Browser automation	Playwright Chromium
Test runner	npx playwright test (23 tests, 1 worker)
Typecheck	tsc -b
Dependency audit	npm audit → 0 vulnerabilities
OS	Windows

3. Security review findings & fixes

Area	Finding	Severity	Fix / status
Dependencies	npm audit reported 0 known vulns	Info	No action required
XSS / DOM	Shemitah overlay used layer.innerHTML = "	Low	Replaced with removeChild loop; labels use textContent
Portfolio storage	JSON parse accepted any assetId / large amounts	Medium	Allow-list asset ids from ASSETS, safeld regex, amount bounds, max 50 holdings, reject __proto__
WebSocket	Trusted host only, but weak message validation	Medium	Validate symbol against subscription list, finite positive price, size cap
Headers	Missing CSP / referrer policy	Medium	Added CSP meta, referrer strict-origin-when-cross-origin, nosniff
Secrets	No API keys in client repo	Info	Public endpoints only — acceptable for this design
Duplicate DOM ids	BTC/SPX cards duplicated in Shemitah section broke uniqueness	Medium	idSuffix='shemitah' for secondary cards
Third-party CORS proxies	Used only as Yahoo backup in production	Low	Documented; static SPX snapshot is primary offline path

4. API tests (Playwright request context)

These hit the same Vite proxy routes the browser uses in development.

Test	Endpoint / check	Result
Binance klines	GET /api/binance/.../klines?symbol=BTCUSDT	PASS
Binance ticker	GET 24hr ETHUSDT lastPrice > 0	PASS
Yahoo SPX	GET chart ^GSPC range=1y, ≥50 closes	PASS
CoinLore global	total_mcap & btc_d present	PASS
Fear & Greed	GET fng limit=10, value 0–100	PASS
Frankfurter FX	USD→EUR rate in (0.5, 2)	PASS
SPX snapshot	GET /data/spx.json (when present)	PASS

5. UI / E2E tests (Playwright)

Test case	How verified	Result
Dashboard shell	Root mounts; CryptoMacro brand; section headings	PASS
Sidebar nav	Macro / Portfolio / Shemitah buttons change main heading	PASS
Mobile nav	4 tabs Home/Macro/Portfolio/Cycles; Settings absent	PASS
Settings removed	No Settings button/heading; #settings does not open settings page	PASS
BTC chart	#asset-btc-usd canvas + Years timeframe unit	PASS
SPX chart	#asset-spx canvas visible	PASS
Fear & Greed	Canvas + pie SVG gauge	PASS
BTC.D aggregate	Canvas on #asset-btc-d	PASS
Hours 1–8	Hours unit exposes 1,2,4,8; select 4 keeps canvas	PASS
Months 1–12	Months unit exposes 12; select 6 keeps canvas	PASS
Portfolio add/FX	Add 0.01 BTC; toggle € EUR then \$ USD	PASS
No export/import UI	Export/Import/Clear buttons count = 0	PASS
Header tape	Global MCap, BTC.D, S&P 500, Fear & Greed labels	PASS
CSP meta	default-src 'self'; object-src 'none'	PASS
No http scripts	No script[src^=http:]	PASS
Unique asset ids	btc-usd/spx once; shemitah suffixed variants exist	PASS

6. Defects found during testing & retest

Defect	Impact	Resolution	Retest
Duplicate #asset-btc-usd / #asset-spx	Broken a11y & flaky selectors	AssetCard idSuffix for Shemitah copies	PASS — unique id test
Portfolio currency button matched Remove BTC/USD	False positive click	Tests use exact '\$ USD' / '€ EUR' names	PASS
Heading /Live Portfolio/ matched two headings	Strict mode failure	Exact heading matchers	PASS

7. Final suite result

23 / 23 tests passed on Chromium after fixes and retest. API suite: 7 passed. UI/security suite: 16 passed. No failing cases remained at report generation time.

Command:
npx playwright test

Summary:
23 passed
0 failed

8. Manual checklist (smoke)

- Open live site on desktop and phone; charts paint within a few seconds.
- Change timeframe units on BTC and SPX; series updates.
- Add portfolio holding; total value and allocation update; USD/EUR switch reformats.
- Confirm Settings is absent from sidebar and mobile bar.
- Hard-refresh after deploy; SPX still renders (snapshot backup).

9. Conclusion

The dashboard meets functional expectations for navigation, market charts, portfolio tracking, and baseline web security for a public static SPA. Automated Playwright coverage now guards regressions on APIs, UI controls, and security meta tags. Remaining residual risks are external API rate limits and third-party CORS proxy availability for Yahoo in pure browser mode — mitigated by the SPX build snapshot and multi-provider crypto paths.